Chmura, urządzenia mobilne, IoT i informacje publiczne

Witchak Modeling, zespół Ziemniaczki: I. Skrypnyk, M. Szyksznia, K. Witczak, O. Wilk

Część A. Chmura

Zagadnienie	Ustalenia
Usługi i dane	Hosting produkcyjny stron, GitHub, CRM, poczta, zarządzanie projektami, Figma i UXPin, zewnętrzna kopia zapasowa. W chmurze są: kod źródłowy, baza klientów i aplikacji, projekty graficzne, umowy i korespondencja.
Dostęp i konta kluczowe	Programiści, graficy, manager projektu i sprzedaż mają dostęp do swoich narzędzi. Najważniejsze konta: właściciel hostingu i organizacji GitHub, administratorzy poczty i CRM, konta serwisowe CI/CD i bazy.
Błędne konfiguracje	Publiczne repozytorium lub zasób, otwarty port bazy, domyślne hasła, zbyt szerokie role, publiczne linki do prototypów, konta byłych pracowników.
Backup	Baza kopiowana codziennie, kopia szyfrowana i niezmienialna w osobnym koncie (3-2-1). Repozytoria i dane SaaS eksportowane co tydzień. Test odtwarzania co kwartał.
MFA	Na wszystkich kontach, obowiązkowo u administratorów, w GitHub, poczcie, CRM i przy dostępie do kopii.
Monitoring	Logowania administratorów i z nowych lokalizacji, zmiany uprawnień, nowe klucze API, zasoby zmienione na publiczne, masowe pobieranie danych, force push, usunięcie kopii.

ID	Ryzyko chmurowe	Zabezpieczenie
R17	Aktywne konta byłych pracowników i wykonawców	Wyłączenie kont w dniu odejścia, przegląd co kwartał.
R18	Usunięcie danych w chmurze po przejęciu konta, razem z kopią	Kopia niezmienialna w osobnym koncie, alert przy usuwaniu.
R19	Przejęcie konta CI/CD i wdrożenie złośliwego kodu na strony klientów	Tokeny z minimalnymi uprawnieniami, zatwierdzanie wdrożeń produkcyjnych.
R5	Błędna konfiguracja chmury (już w rejestrze)	Lista kontrolna, zasoby prywatne domyślnie, alert przy zmianie na publiczne.

Część B. Urządzenia mobilne

Obszar	Zasada
Urządzenia firmowe	Szyfrowany dysk, blokada ekranu, antywirus lub EDR, brak praw administratora u użytkownika, programy tylko z zatwierdzonej listy.
Urządzenia prywatne	Tylko poczta i narzędzia SaaS w wydzielonym profilu, z możliwością zdalnego wylogowania. Bez dostępu do serwera plików i VPN.
Praca zdalna i poczta	VPN do zasobów biura, MFA do poczty, brak pracy w publicznym Wi-Fi bez VPN, zakaz przekazywania poczty na prywatne konta.
Dostęp do danych	Najmniejsze uprawnienia, dane klientów tylko na serwerze lub w chmurze, nie lokalnie.
Aktualizacje i szyfrowanie	Automatyczne aktualizacje, szyfrowanie dysków i telefonów. Urządzenie bez aktualizacji powyżej 30 dni traci dostęp do poczty i VPN.

Utrata telefonu lub laptopa. Pracownik od razu zgłasza ją administratorowi IT. Administrator blokuje i zdalnie wymazuje urządzenie, unieważnia sesje i tokeny, wymusza zmianę haseł i MFA oraz sprawdza logi logowań. Jeśli mogły być na nim dane osobowe i nie ma pewności co do szyfrowania, organizacja zgłasza naruszenie do UODO w 72 godziny (art. 33 RODO), a przy kradzieży także policji.

Ryzyko nowe: R20 (praca na prywatnych urządzeniach bez kontroli).

Część C. IoT

Pytanie	Kamera IP w biurze
Komunikacja i sieć	Rejestrator w biurze i czasem chmura producenta. Podłączona do VLAN 30 (IoT), bez dostępu do stacji i serwerów.
Zarządzanie i aktualizacje	Administrator IT, unikalne hasło. Oprogramowanie sprzętowe sprawdzane co miesiąc, urządzenie bez wsparcia producenta jest wymieniane.
Skutki przejęcia	Podgląd biura i ekranów, wyciek nagrań, wejście do sieci firmy.

Separacja. Firewall blokuje ruch z VLAN 30 do pozostałych sieci. Dozwolone jest tylko zapisywanie nagrań na rejestrator. Panel kamery nie jest dostępny z Internetu, administracja tylko ze stacji administratora lub przez VPN. Ryzyko nowe: R21 (przestarzałe oprogramowanie IoT).

Część D. Informacje publiczne

Informacja	Wykorzystanie w socjotechnice	Ochrona
Nazwiska i stanowiska	Wybór osoby do podszycia (Tech Lead, administrator).	Mniej szczegółów, potwierdzanie próśb drugim kanałem.
Adresy e-mail	Wzór imie.nazwisko@firma pozwala odgadnąć adresy całego zespołu.	Adresy rolowe na stronie, SPF, DKIM, DMARC.
Technologie i klienci (Figma, UXPin, portfolio)	Fałszywe powiadomienie z Figma lub faktura ze zmienionym numerem konta.	Szkolenie, potwierdzanie zmiany konta telefonem.
Zdjęcia biura i media społecznościowe	Widoczne ekrany, karty dostępu, nazwa Wi-Fi.	Zasady publikacji, sprawdzanie tła zdjęć.

To analiza ogólna, bez logowania, skanowania i sprawdzania prawdziwych organizacji. Ryzyka nowe: R22 i R23.

Nowe ryzyka w rejestrze

ID	Nowe ryzyko	Praw.	Skutek	Poziom
R17	Aktywne konta byłych pracowników i wykonawców	3	4	12
R18	Usunięcie danych w chmurze razem z kopią	2	5	10
R19	Przejęcie konta CI/CD i złośliwy kod na stronach klientów	3	5	15
R20	Praca na prywatnych urządzeniach bez kontroli	4	3	12
R21	Przestarzałe oprogramowanie kamery i drukarki	3	3	9
R22	Spear phishing na podstawie informacji publicznych	4	4	16
R23	Ujawnienie szczegółów wewnętrznych na zdjęciach	2	3	6